



Product Handbook & Technical Audit

Product truth, architecture, operations, quality evidence, risks, and release guidance

Verified 15 August 2026 | Version 1.0 | casparel.com

4	173	39/39	224 ms
CLIENT SURFACES	API TESTS	BROWSER RENDERS	HTTP P95

Executive brief

PRODUCT POSITION Casparel is strongest when it moves a learner from discovery to source evaluation, organized study, and evidence. It should not position itself as a generic AI chatbot or social feed.

The web/API foundation is materially stronger than a typical hackathon prototype: the production service is reachable, the automated API suite passes, a broad browser matrix is exercised, and teacher/resource workflows are unusually complete. The audit also found genuine release blockers in mobile packaging, quota behavior, product claims, public discovery, ownership controls, load-test safety, and coverage. Those findings were corrected rather than merely documented.

Area	Assessment	What matters now
Web + API	Production-capable	Keep monitoring; expand interaction and contract coverage.
Mobile	Code-complete subset	Prove signed builds, devices, stores, and purchases.
Desktop	Controlled shell	Signing, notarization, updater, and offline expectations remain.
Product evidence	Synthetic evidence strong	Run moderated student and teacher sessions.

What was verified

- 23 API test files and 173 tests passed in the isolated final run.
- The web production build completed across 2,734 transformed modules.
- The browser matrix passed 39 of 39 public/signed-in, theme, and viewport renders.
- Session handling passed valid, expired, and server-rejected token journeys.
- The desktop package compiled and passed four real Electron smoke scenarios.
- A production-safe HTTP smoke returned 20 of 20 HTTP 200 checks with 224 ms overall p95.

EVIDENCE BOUNDARY No real account was created, no purchase was made, no recruited participant was tested, and no destructive production load was applied. Store distribution, RevenueCat dashboard state, and concurrent capacity remain unverified.

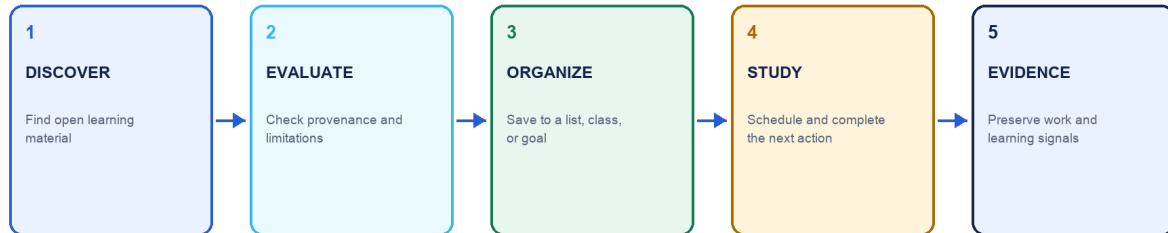
Contents

A navigational overview of this report. Section headings are preserved as real Word headings for the document outline and accessibility tools.

Section	What it covers
01	Product definition and user value
02	User-facing surfaces and journeys
03	Architecture, repository, and request lifecycle
04	Identity, plans, limits, discovery, and research
05	Data model, integrations, and configuration
06	Development, deployment, and operations
07	Security, privacy, and accessibility
08	Quality, performance, and task-based user review
09	Implemented improvements
10	Risk register and prioritized next steps
A	Operator command reference and source register

01 • Product definition and user value

Casparel is a cross-platform learning workspace for students and teachers. Students discover credible educational material, organize it around goals, schedule study, collaborate, and preserve evidence of progress. Teachers manage classes, recommend resources, create learning activities, and use evidence to support students.



The product's durable differentiation is the complete credibility-to-action loop.

Primary audiences

Audience / state	Needs	Casparel response
Signed-out visitor	Understand value and browse safely	Landing, public resource library, details, legal, and account entry.
Student	Find trustworthy material and turn it into action	Goals, schedules, resources, lists, classes, activities, canvases, collaboration, and evidence.
Teacher	Guide classes and inspect learning	Class management, assignments, recommendations, notes, seating, and Google Classroom integration.
Administrator	Moderate and operate the system	Verification queues, user/class controls, reports, and usage/cost visibility.
Premium account	Use deep live-web research without account limits	Unlimited account-level deep source research; server-wide safety budget still applies.

Product promise and boundaries

- The public learning-resource library and quick source check remain useful without Premium.
- Premium removes account-level limits from deep, cited, live-web source research; it does not remove the global emergency budget.
- Mobile is intentionally narrower than web and must never advertise missing native capabilities.
- Source reports are research aids, not objective trust scores; limitations and supporting links must remain visible.
- Desktop is a controlled online shell, not an offline-native product.

02 • User-facing surfaces and journeys

Web application

Area	Representative pages	Purpose
Public	Landing, login, registration, legal, Resources, Support	Acquisition, public discovery, trust, and account entry.
Home	Dashboard, adaptive dashboard, guide	Orientation, recommended action, and onboarding.
Learning	Goals, activities, schedule, canvases	Planning, focused work, and evidence.
Resources	Search, detail, lists, catalog	Discovery, evaluation, citation, and collections.
Community	People, profiles, messages, forum	Safe discovery and collaboration.
Teaching	Classes and class detail	Membership, assignments, resources, goals, notes, and seating.
Account	Profile and settings	Identity, integrations, privacy, and plan state.
Operations	Admin	Verification, moderation, support, and AI-usage visibility.

Mobile application

The Expo Router app focuses on onboarding/login, dashboard, classes, schedule, resource browse/detail, quick and deep source review, profile, usage, and the Premium paywall. Native identifiers are com.casparyl.app; the Expo slug and scheme are casparyl. RevenueCat uses entitlement identifier premium and logs in with the numeric Casparyl user ID.

TRUTHFUL SCOPE Goals, canvases, lists, messaging, forum, activities, admin, and AI-assisted catalog discovery are not complete native experiences. Paywall and store copy must describe only what the submitted binary actually provides.

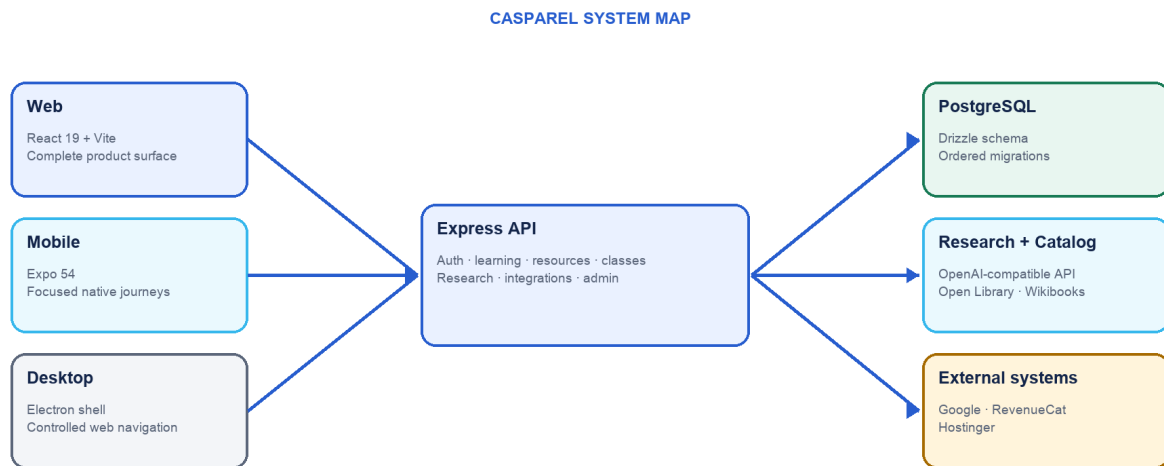
Desktop and shared design system

The Electron package wraps CASPAREL_URL, validates navigation and deep links, preserves the window on embed failure, and has a real-window smoke test. The historical schoolar-edu package provides shared tokens and components across web and mobile; its legacy package name remains a compatibility detail.

Critical journeys

1. Public discovery: open Resources, inspect starter material, search, and open a resource without registering.
2. Credibility-to-action: run a quick or deep review, interpret strengths/limitations, then save or connect the resource to study work.
3. Student organization: create a goal, plan time, complete activity, and preserve evidence.
4. Teacher loop: create or manage a class, recommend/assign material, and review learning evidence.
5. Subscription loop: use the free allowance, view the honest paywall at the effective limit, purchase/restore, and reconcile entitlement server-side.
6. Session recovery: expire or reject a token, clear local state, and return safely to login.

03 • Architecture, repository, and request lifecycle



Client surfaces share one API and data model; desktop delegates to the web experience.

Repository map

Path	Responsibility
artifacts/api-server	Express 5 API, authentication/authorization, integrations, and startup migrations.
artifacts/app	React 19 + Vite SPA, production pages, and browser/session audit fixtures.

Path	Responsibility
artifacts/mobile	Expo 54 / React Native native client and RevenueCat adapter.
artifacts/desktop	Electron shell, deep links, packaging, and runtime smoke.
artifacts/schoolar-edu	Shared design tokens and web/native components.
lib/api-spec	OpenAPI source of truth and code generation endpoint.
lib/api-client-react	Generated React Query client; never hand-edit generated files.
lib/api-zod	Generated request/response schemas; never hand-edit generated files.
lib/db	Drizzle schema and ordered migrations.
load-tests	k6 smoke, public, and authenticated profiles with production guards.

Request lifecycle

1. A web or native client calls an endpoint below /api.
2. The server applies security headers, CORS/body limits, and rate controls.
3. Protected routes validate the signed bearer token; teacher/admin routes apply stronger authorization.
4. Typed core routes validate payloads with generated Zod schemas.
5. Data is read or written through Drizzle or parameterized SQL.
6. Startup applies ordered migrations and checks database reachability/schema health before serving traffic.

CONTRACT DEBT Forum, messaging, workflow, activity, canvas, expanded admin, and webhook surfaces are not all represented in OpenAPI. Migrate them spec-first in bounded domain batches to recover generated-client drift protection.

04 • Identity, plans, limits, discovery, and research

Authentication and session behavior

- Registration and login return a signed bearer token.
- The compatibility token key is schoolar_token on web and mobile; renaming it would break existing sessions.
- Expired or server-rejected tokens are cleared and redirect to login.
- Logout clears local session state; account deletion anonymizes/disables identity.
- The mobile user cache now uses casparel_user and migrates the legacy schooler_user value.

Plan reconciliation and quotas

Control	Current rule	Purpose
AI discovery fallback	3 per user/day by default	Contain optional fallback cost.
Deep research - day	2 per free user/day	Give every account a meaningful trial.
30-day research	2 per free user/30-day window	Longer-window cost control.
Global deep research	20/day by default, including Premium	Emergency server-wide budget.
Premium	Account-level deep limits removed	Monetized convenience; global safety remains.

RevenueCat drives immediate native entitlement state and posts signed webhook events to POST /api/webhooks/revenuecat. The server records premium plan/expiry state. Persistent event idempotency and authoritative TRANSFER reconciliation remain release-critical work.

Layered discovery

1. Query Casparel's stored public library.
2. Query the locally stored open-education catalog.
3. Fetch and cache Open Library or Wikibooks material when the first catalog page is sparse.
4. Only when no catalog result exists and a feature flag permits it, use the paid AI fallback.

Source research

Quick mode uses model knowledge. Deep mode performs live-web research and returns cited strengths, concerns, limitations, currency, and reputation analysis. Results are cached; concurrent work is restricted by user/resource; both account and global quotas apply. The interface must preserve uncertainty and supporting links.

05 • Data model, integrations, and configuration

Data domains

Domain	Representative records
Identity + safety	Users, preferences, reports/safety state, activity log.
Teaching	Classes, members, invitations, assignments, recommendations.
Learning	Goals, evidence, workflow events, sessions, schedule blocks.
Resources	Public/catalog resources, reviews, source-review cache, lists/items.
Collaboration	Conversations, messages, forum content, comments/reports, canvases.

Domain	Representative records
Integrations	Google OAuth and Calendar tokens; subscription account state.

MIGRATION INVARIANT Every database schema change requires both the TypeScript schema edit and its generated Drizzle migration. Do not use drizzle push or direct ALTER TABLE. Timestamp fields feeding string schemas use mode: "string".

External integrations

Integration	Purpose	Required configuration
PostgreSQL	Persistent state and quota counters	DATABASE_URL
OpenAI-compatible	Discovery fallback and source research	Base URL + API key
Google Classroom	Course import, students, resource sharing	Client ID/secret + redirect
Google Calendar / iCal	Connected/exported scheduling	OAuth settings + calendar redirect
RevenueCat	Products, offerings, entitlement	Public SDK keys + webhook auth
Hostinger	Production hosting and smoke verification	Deployment secrets + SITE_URL

Required server configuration

```

DATABASE_URL=...
SESSION_SECRET=...
AI_INTEGRATIONS_OPENAI_BASE_URL=...
AI_INTEGRATIONS_OPENAI_API_KEY=...

```

Optional controls cover RevenueCat webhook authentication, Google OAuth, admin allowlists, CORS origins, catalog remote fetch, AI flags/quotas, logging, and strict database readiness. Secrets belong in host-managed environment variables or gitignored .env files, never source or committed documentation.

06 • Development, deployment, and operations

Local startup

```

pnpm install --frozen-lockfile
pnpm --filter @workspace/api-server run dev
pnpm --filter @workspace/app run dev
pnpm --filter @workspace/mobile run dev
pnpm --filter @workspace/edu-ds run dev

```

Service boundaries

Service	Default	Rule
API	8080 Replit / 5000 local	Read PORT; server process remains separate.
Web	23863	Read PORT and API_URL; proxy /api to API.
Design system	20495	Run only for design-system development.
Mobile	18115	Expo development server; native store builds use EAS.

Quality gates

```
pnpm run typecheck
pnpm --filter @workspace/api-server exec vitest run
pnpm --filter @workspace/api-server run build
pnpm --filter @workspace/app run build
node artifacts/app/scripts/audit-pages.mjs
node artifacts/app/scripts/audit-session.mjs
pnpm --filter @workspace/desktop run compile
pnpm --filter @workspace/desktop run smoke
```

Contract and schema workflow

- API change: edit lib/api-spec/openapi.yaml, run the api-spec code generator, then add/register the Express handler.
- Generated React Query and Zod directories are output-only; never hand-edit them.
- Database change: edit the Drizzle schema, generate a migration, inspect and add safety guards, commit both together.
- The authentication token key and port/environment contracts are compatibility boundaries, not cosmetic naming opportunities.

Deployment and incident first checks

1. Call GET /api/healthz and inspect deployment logs.
2. Confirm required environment variables are bound.
3. Confirm migrations ran cleanly and the expected schema exists.
4. Verify DATABASE_URL reachability and readiness diagnostics.
5. Inspect RevenueCat webhook responses during entitlement incidents.
6. Use only the bounded production smoke; run public/authenticated capacity profiles on staging with telemetry.

07 • Security, privacy, and accessibility

Implemented controls

- Password hashing, signed tokens, route-level authorization, input/body limits, and request throttling.
- Parameterized data access, CORS policy, security headers, upload validation, and startup readiness checks.
- Moderation/reporting controls, minimal OAuth scope handling, signed RevenueCat webhooks, and redaction-aware logs.
- Public terms/privacy/support pages and an account deletion path.
- Automated browser assertions for runtime failures, contrast, accessible names, labels, headings, alt text, and overflow.

Residual security findings

Finding	Severity	Mitigation / resolution
RevenueCat TRANSFER reconciliation	P1	Persist event IDs and reconcile both subscriber aliases against authoritative state.
image-size ICNS denial of service	High / build-time	Avoid untrusted ICNS input; upgrade when a fixed release is available.
image-size JXL/HEIF denial of service	High / build-time	Avoid untrusted JXL/HEIF input; upgrade when a fixed release is available.
Newer routes outside OpenAPI	P1	Migrate domains spec-first and remove duplicate manual types.

Manual accessibility gates

Automated checks cannot establish comprehension, focus usability, or screen-reader quality. Before native release, run VoiceOver and TalkBack on physical devices, Dynamic Type, reduced motion, keyboard/switch control, poor-network behavior, and package-selection/restore journeys.

08 • Quality, performance, and task-based user review

Verification dashboard

Check	Result	Evidence
API tests	PASS	23 files; 173 tests.
Web + mobile TypeScript	PASS	Workspace and focused final checks.
Expo public configuration	PASS	Casparel slug/scheme, IDs, production origin.
Web build	PASS	2,734 modules transformed.
Browser matrix	PASS	39/39 route/theme/viewport renders.
Session journeys	PASS	Valid, expired, and server-401 flows.
Desktop	PASS	Compile + four real-window smoke cases.
Production HTTP smoke	PASS	20/20 checks; 0% failures.
Dependency audit	PARTIAL	Three high findings fixed; two image-size highs remain.
Store install	NOT VERIFIED	Signed binaries/store credentials required.
Moderated usability	NOT RUN	Participant recruitment required.
Concurrent capacity	NOT RUN	Staging with database/CPU telemetry required.

Production-safe smoke latency

20/20 HTTP checks · 0% failures · 1 virtual user



p95 response time (milliseconds)

Read-only, one-user latency sample; not a capacity claim.

Web bundle profile

Chunk	Raw	Gzip	Interpretation
Entry	72.5 kB	24.8 kB	Healthy application entry.
React vendor	185.8 kB	58.6 kB	Expected framework cost.
Radix vendor	148.0 kB	45.9 kB	Shared accessible primitives.
Canvas	203.6 kB	65.9 kB	Feature-specific; keep lazy.
Three.js	617.4 kB	157.0 kB	Heavy but isolated.
p5	1,129.2 kB	331.0 kB	Largest lazy dependency; measure before optimizing.

Task-based expert and synthetic review

Task	Result	Finding
Understand landing	PASS	Clear audiences and actions; no observed runtime errors.
Browse Resources signed out	FIXED	Starter cards now load from the existing top-rated API.
Clear search accessibly	FIXED	Explicit accessible name added.
Recover expired session	PASS	Token clears and login appears.
Remove own resource	FIXED	Remove control now appears only to the submitter.
Use free deep research	FIXED	Mobile consumes the server allowance before paywall.
Understand Premium	FIXED	Unsupported discovery/priority claims removed.
Select/restore accessibly	PARTIAL	Semantics improved; physical assistive-tech pass remains.
Teacher/admin workflow	PARTIAL	Major views render; live end-to-end creation/moderation was not executed.

Moderated research plan

Recruit at least five students and five teachers, including keyboard-only and screen-reader representation where possible. Give tasks rather than tours; measure completion, time, misclicks, comprehension, confidence, and unaided recall.

1. Find a credible resource for a real topic and explain why it is trustworthy.
2. Save it, cite it, and connect it to a goal.
3. Schedule study and find the plan again the next day.
4. Join or manage a class and explain what is private versus shared.
5. Compare quick and deep research and explain the Premium allowance.

09 • Implemented improvements

1. Added mobile and api-spec to the pnpm workspace; regenerated a complete lockfile.
2. Separated Expo runtime dependencies from build/type-only dependencies.
3. Corrected Expo slug, scheme, and production Router origin to Casparel.
4. Made root CI typecheck responsible for mobile instead of a redundant npx workaround.
5. Let free mobile users consume their deep allowance before showing the paywall.
6. Made usage reporting respect both day and 30-day deep counters.
7. Removed unsupported Premium claims and strengthened native labels, roles, and selected state.
8. Added public starter resources, public Support, and browser audit coverage.
9. Restricted web resource removal controls to the submitting user.
10. Corrected environment flags, budgets, and production origins.
11. Protected casparel.com from accidental non-smoke k6 profiles and bounded smoke iterations.
12. Made the Electron runtime smoke portable across Linux, macOS, and Windows layouts.
13. Raised PostCSS and nanoid security floors, clearing three high-severity advisories.
14. Added canonical product, audit, and Shipaton documentation.

10 • Risk register and prioritized next steps

Priority	Risk	Required action	Exit evidence
P0	No verified iOS/Android store release	Configure EAS/credentials, build, install on devices, pass review.	Public US listing + clean install.
P0	RevenueCat lifecycle unproven	Test purchase, renewal, restore, cancellation, expiry, transfer.	Transaction matrix + server entitlement.
P1	TRANSFER/idempotency gap	Persist event IDs and reconcile authoritative subscriber state.	Replay-safe tests and incident diagnostics.
P1	No moderated user evidence	Run five student + five teacher sessions and fix top failures.	Task metrics + consented evidence.
P1	Manual native accessibility incomplete	VoiceOver, TalkBack, Dynamic Type, motion, keyboard/switch passes.	Device checklist with no P0/P1 defects.
P1	No client RUM/error funnel	Add privacy-conscious telemetry and define SLOs.	Activation/crash/performance dashboard.
P1	Contract coverage incomplete	Move newer API domains into OpenAPI in batches.	Generated clients and drift tests.
P2	Generic SPA metadata	Add route-aware metadata or prerender/SSR.	Crawl validation per public route.
P2	Heavy specialist chunks	Define route budgets and optimize from measured impact.	RUM-backed performance regression budget.

RELEASE RECOMMENDATION Web/API can continue in production with normal monitoring. Mobile is not yet store- or Shipaton-ready: signed builds, RevenueCat transaction proof, public publication, manual accessibility, and moderated usability are release gates.

Appendix A • Operator command reference

Install and validate

```
pnpm install --frozen-lockfile
pnpm run typecheck
pnpm --filter @workspace/api-server exec vitest run
pnpm --filter @workspace/api-server run build
pnpm --filter @workspace/app run build
```

Browser and desktop

```
node artifacts/app/scripts/audit-pages.mjs
node artifacts/app/scripts/audit-session.mjs
pnpm --filter @workspace/desktop run compile
pnpm --filter @workspace/desktop run smoke
```

Production-safe smoke

```
BASE_URL=https://casparel.com SMOKE_ITERATIONS=5 pnpm run loadtest:smoke
```

Generate typed API clients

```
pnpm --filter @workspace/api-spec run codegen
```

Appendix B • Source register

Casparyl production: <https://casparel.com/>

RevenueCat Shipaton 2026 rules: <https://revenuecat-shipaton-2026.devpost.com/rules>

RevenueCat preparation guide: <https://revenuecat.github.io/codelabs/shipaton-2026-prep.html>

RevenueCat webhook event fields: <https://www.revenuecat.com/docs/integrations/webhooks/event-types-and-fields>

RevenueCat webhook event flows: <https://www.revenuecat.com/docs/integrations/webhooks/event-flows>

Expo Router production origin: <https://docs.expo.dev/versions/latest/sdk/router/>

image-size ICNS advisory: <https://github.com/advisories/GHSA-w3rx-r6r6-pgpr>

image-size JXL/HEIF advisory: <https://github.com/advisories/GHSA-5p2g-fcmc-qvqq>

Repository evidence is tied to commit e0dfa942d425f05fa4a65f439d0a890bbf1b4bb6. Competition rules and external service behavior can change; re-verify them before release or submission.